Wazuh-Based Security Monitoring and Incident Response Platform

Design, implementation and validation of a SOC laboratory

Selma | Master's in IS Audit and Security, FSEG Sfax | October 2026

Abstract

This report presents a defensive cybersecurity laboratory built around Wazuh, an open source security monitoring platform (SIEM/XDR). The laboratory collects telemetry from several systems, detects suspicious behavior, enriches alerts with threat intelligence, notifies the analyst in real time and triggers automated containment actions. Each capability was validated through a controlled test scenario in an isolated virtualized environment. The document describes the architecture, the implementation, the results obtained, the difficulties encountered and the mapping to MITRE ATT&CK and ISO/IEC 27001:2022.

1. Context and problem statement

Information systems continuously produce events: authentications, process executions, file modifications. Analyzed in isolation, they cannot be exploited at scale. A security operations center (SOC) centralizes them, spots abnormal activity and coordinates the response. The delay between detection and containment determines the impact of an incident, and reducing it through automation is a major challenge.

Problem statement. How can a complete detection and response chain be built with open source tools, and how can its operation be demonstrated in a reproducible way?

2. Objectives

- Centralize the monitoring of several Windows and Linux endpoints.
- Collect detailed telemetry (processes, files, authentications).
- Detect file modifications and suspicious behavior.
- Enrich alerts with an external threat intelligence source.
- Notify the analyst in real time, without continuous dashboard monitoring.
- Automate containment on Linux (network) and on Windows (file).
- Validate each capability with a controlled test and keep the evidence.

3. Architecture

System	Role
Wazuh server (Ubuntu, 192.168.56.102)	Manager (analysis and rules), Indexer (storage), Dashboard (visualization), Filebeat (alert forwarding)
Windows 11 endpoint	Wazuh agent, Sysmon, file integrity monitoring, quarantine response
Ubuntu endpoint	Wazuh agent, SSH and sudo authentication logs
Kali Linux	Controlled attack machine (Hydra), no agent
VirusTotal	External file reputation analysis service
Discord	Analyst notification channel

The system follows a single flow: agents send their events to the manager, which analyzes them with decoders and rules; alerts are indexed and displayed in the dashboard; depending on the rule triggered, the manager queries VirusTotal, notifies Discord and can order a response action on the relevant agent.

Functional flow: Monitor → Detect → Enrich → Notify → Respond → Contain.

Everything runs in a private virtual network. Simulated attacks target only the laboratory machines, and the server has Internet access to query the external services.

4. Implementation

4.1 Telemetry collection

Wazuh agents are deployed on the Windows 11 and Ubuntu endpoints and enrolled with the manager. Enrollment is validated in the dashboard by the active status of the agents.

4.2 Sysmon

Sysmon enriches Windows logs with process creation (ID 1), network connections (ID 3) and file creation (ID 11). The agent collects the Microsoft-Windows-Sysmon/Operational channel. Observed example: the launch of cmd.exe by an unusual process triggers rule 92052, mapped to MITRE technique T1059.003.

4.3 File Integrity Monitoring (FIM)

A test folder is monitored in real time by the syscheck module. File creations, modifications and deletions produce rules 554, 550 and 553 respectively.

4.4 VirusTotal enrichment

The integration applies to alerts of the syscheck group: the hash of the detected file is submitted to VirusTotal. When engines flag the file, rule 87105 (level 12) is generated. The EICAR test file, a harmless standard dedicated to detection testing, was recognized by 66 engines out of 68.

4.5 Discord notification

A custom integration, made of a launcher and a Python script, formats the alert into a structured message: agent, severity, rule, description, MITRE technique, affected file or IP and the associated response action. Only alerts of level 8 and above are forwarded, and empty fields are omitted to keep the message readable.

4.6 Automated responses (Active Response)

Linux: IP blocking. When rule 5712 detects an SSH brute force, the firewall-drop command adds a firewall rule that blocks the source IP for 300 seconds, then removes it automatically.

Windows: file quarantine. When rule 87105 triggers, a .cmd launcher calls a PowerShell script that reads the file path from the VirusTotal alert, moves the file to a quarantine folder under a timestamped name and records the operation in a log. The file is kept rather than deleted, to allow investigation.

5. Validation and results

Test scenario	Expected result	Result obtained
Sysmon activity (process creation)	Alert with MITRE mapping	Rule 92052, T1059.003
File creation, modification, deletion	FIM alerts	Rules 554, 550, 553
EICAR file drop	VirusTotal enrichment and critical alert	Rule 87105, level 12, 66 engines out of 68
SSH brute force from Kali (Hydra)	Rule 5712 and source IP blocked	IP blocked for 300 s, then unblocked

Test scenario	Expected result	Result obtained
Alert of level 8 or above	Structured Discord message	Message received with the expected fields
EICAR after rule 87105 alert	File moved to quarantine and logged	Timestamped file in quarantine, SUCCESS entry in the log

Each test has a screenshot, a log, or both, kept in the project repository.

6. Difficulties encountered and resolutions

Problem	Cause	Resolution
Empty dashboard despite generated alerts	Filebeat service stopped, index template missing	Diagnosis through the service status and the indexer API, template reloaded
One file produces two FIM events	An empty file is created first, then the content is written	Only the second hash is recognized by VirusTotal (65 to 66 out of 68) and triggers the response
VirusTotal requests without result	Free tier quota (4 requests per minute)	Tests spaced out
Quarantine not executed on the first attempt	The agent had not yet reloaded its response configuration	Isolated script test, then full chain test after synchronization

7. Mapping to MITRE ATT&CK and ISO/IEC 27001:2022

Detection or capability	MITRE ATT&CK	ISO/IEC 27001:2022 control
Suspicious process creation (rule 92052)	T1059.003	A.8.16 Monitoring activities
File modification (rule 550)	T1565.001	A.8.15 Logging
Malicious file (rule 87105)	T1203	A.8.7 Protection against malware

Detection or capability	MITRE ATT&CK	ISO/IEC 27001:2022 control
SSH brute force (rule 5712)	T1110	A.8.16 Monitoring activities, A.5.26 Response to information security incidents
Automated notification and containment	-	A.5.24 to A.5.26 Information security incident management

This grid links the technical implementation to the controls of an information security management system: each building block of the laboratory is operational evidence of an Annex A control.

8. Critical analysis and limitations

- **Response status.** The “Actions Taken” field of the notifications indicates that a response is triggered, not that it succeeded. Proof of success relies on the system state and the quarantine log.
- **Test representativeness.** EICAR and the simulated brute force validate the technical chain, but do not replace realistic attack scenarios.
- **External service dependency.** Enrichment depends on the availability and quota of the VirusTotal API.
- **False positive risk.** An automatic block or quarantine can disrupt legitimate use, hence the temporary block and the retention of the file rather than its deletion.
- **Test configuration.** Antivirus exclusions limited to the test folders were necessary and are removed at the end of the lab.

9. Future work

- Use Active Response confirmation alerts to distinguish a triggered response from a successful one.
- Develop custom detection rules and tune alert noise.
- Replay documented attack scenarios (Atomic Red Team) to measure MITRE coverage.
- Integrate an orchestration and case management platform (Shuffle, TheHive).

10. Conclusion

The laboratory demonstrates a functional end-to-end SOC chain: collection, detection, enrichment, notification and automated containment, on Windows and Linux systems. The difficulties encountered and their resolution made it possible to understand its weak points: alert forwarding, FIM behavior, external service quotas and response synchronization. The mapping to MITRE ATT&CK and ISO/IEC 27001:2022 places this work at the interface between detection engineering and security auditing.

References

- Wazuh documentation: documentation.wazuh.com
- MITRE ATT&CK: attack.mitre.org
- ISO/IEC 27001:2022, Annex A
- Microsoft Sysinternals, Sysmon
- VirusTotal, file reputation API
- EICAR, standard antivirus test file

Appendix: project repository

Scripts, configuration snippets without secrets and validation screenshots: github.com/SelmaBorgi/wazuh-soc-lab